Introduction

The purpose of this document is to evaluate potential security weaknesses and implement security controls within the mobile app's infrastructure.

Scope of Work

This exercise focuses on 1 user story within the Zentra Bank mobile app:

1. As a user, I want to **receive push notifications** so that I stay informed about important updates in my account

Out of Scope

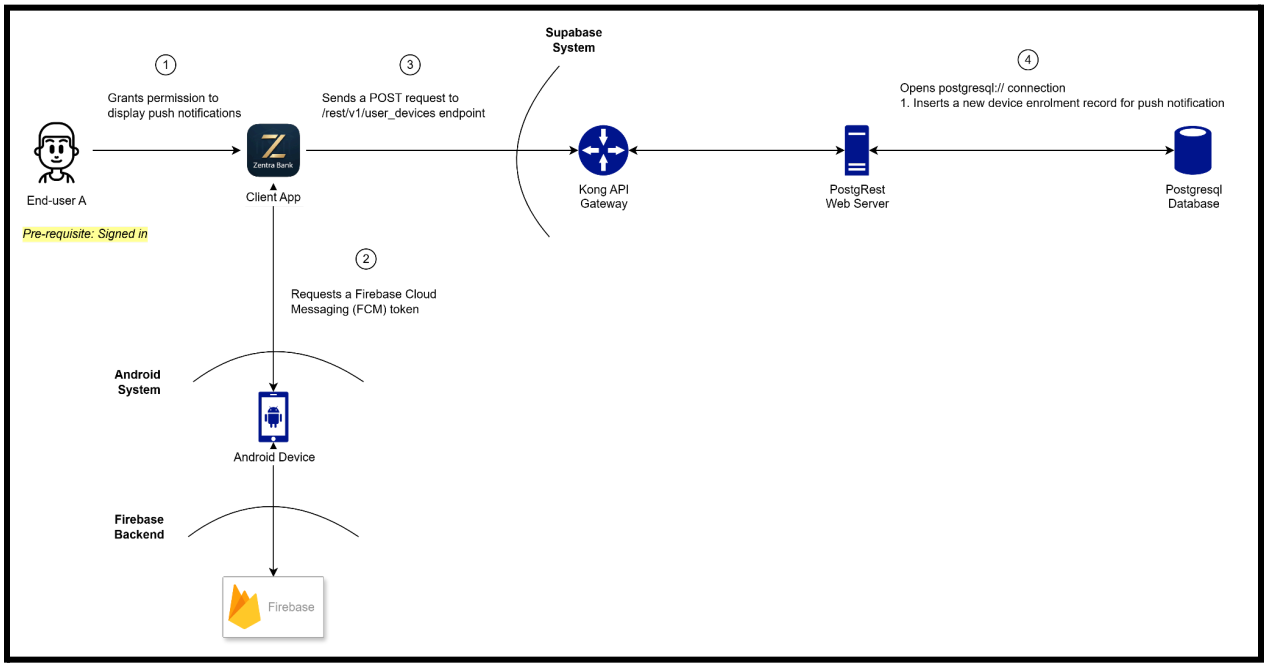
This exercise strictly focuses on the mobile application and its functionalities. Any components outside the mobile app, which includes but not limited to REST APIs, server infrastructure, remote database, and external services, are not within the scope.

User story 6

The data flow for this user story consists of 2 key stages: 1) End-user A enables push notification and waits to receive one. 2) End-user B transfers money to End-user A, which triggers that notification. The detailed steps are as follows:

"As a user, I want to receive push notifications so that I stay informed about important updates in my account"

<u>1) End-user A enables push notification and waits to receive one.</u>

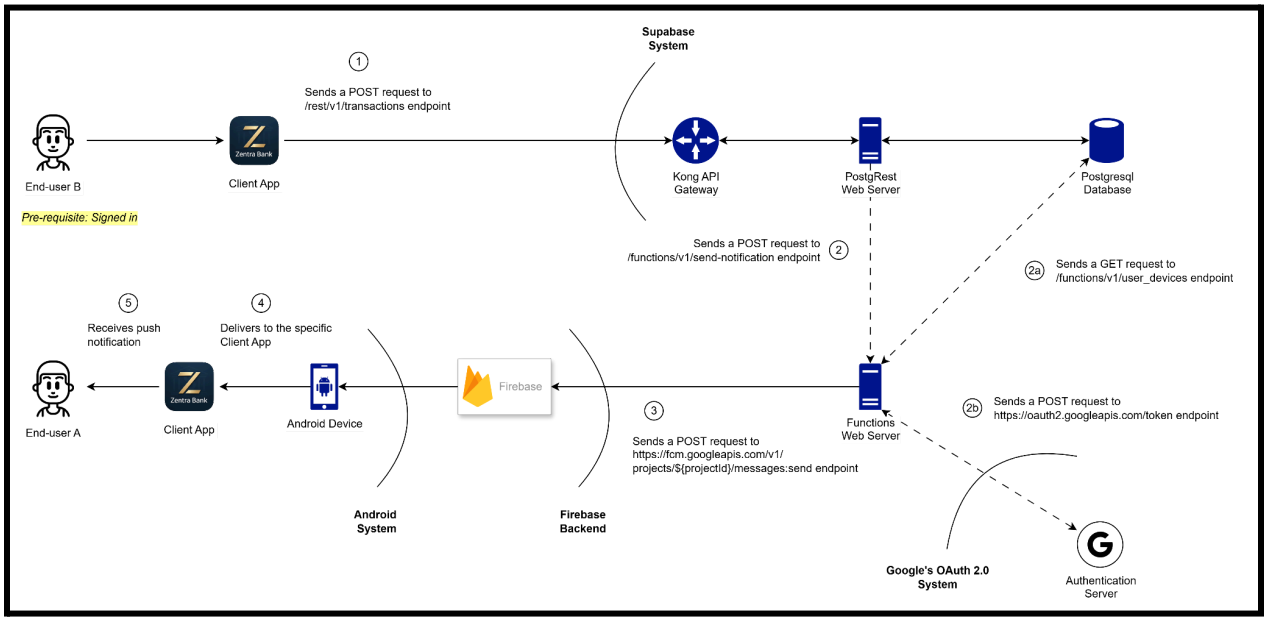


1. The End-user A grants the Client App (CA) permission to display push notifications
2. The Client App (CA) requests a Firebase Cloud Messaging (FCM) registration token via the Firebase SDK, which internally forwards the request to Google Play Services that communicates with the FCM backend
    a. A FCM registration token is a unique string that identifies each client app instance
3. The Client App (CA) receives the FCM registration token and makes an insert request via REST API to the Web server

```
REQUEST:
https://vomohccmapvpspaupbah.supabase.co/rest/v1/user_devices?on_conflict=user_id%2Cplatform
{"body":
"{\"user_id\":\"a9b643b3-9644-43acc-ae74-cc8a14b821bc\",\"account_id\":\"6e7084a4-da6c-48eb-bd16-6f
9f50de1c5e\",\"fcm_token\":\"f6OonhSMR4-T12_7BD_EwM:APA91bHQ3p7_lY07KQD7WcDxxxdJsJPHoxoNBNHzunt5e9F
zOzxadYj2bYCxqjFjjpYkhLXfptcLkbYxSpzDvdv_S25s_5epISM4h3t2n-B18Nq2egtGP8g\",\"platform\":\"android\"
,\"is_active\":true,\"updated_at\":\"2025-09-17T01:34:51.239Z\"}", "headers": {"map": {"apikey":
"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJzdXBhYmFzZSIsInJlZiI6InZvbW9oY2NtYXB2cHNwYXVwYmFoI
iwicm9sZSI6ImFub24iLCJpYXQiOjE3NDg0ODA2MjQsImV4cCI6MjA2NDA1NjYyNH0.kAtm3_e8PUjQGsacDTt7nzrBmQ49H-wU
4J4_biPMSZQ", "authorization": "Bearer
eyJhbGciOiJIUzI1NiIsImtpZCI6Ik4vampuNklBTGRLeHZpRmUiLCJ0eXAiOiJKV1QifQ.eyJpc3MiOiJodHRwczovL3ZvbW9o
Y2NtYXB2cHNwYXVwYmFoLnN1cGFiYXNlLmNvL2F1dGgvdjEiLCJzdWIiOiJhOWI2NDNiMy05NjQ0LTQzYWMtYWU3NC1jYzhhMTR
iODIxYmMiLCJhdWQiOiJhdXRoZW50aWNhdGVkIiwiZXhwIjoxNzU4MDc2NDkwLCJpYXQiOjE3NTgwNzI4OTAsImVtYWlsIjoidG
VzdEB0ZXN0LmNvbSIsInBob25lIjoiIiwiYXBwX21ldGFkYXRhIjp7InByb3ZpZGVyIjoiZW1haWwiLCJwcm92aWRlcnMiOlsiZ
W1haWwiXX0sInVzZXJfbWV0YWRhdGEiOnsiZW1haWwiOiJ0ZXN0QHRlc3QuY29tIiwiZW1haWxfdmVyaWZpZWQiOnRydWUsInBo
b25lX3Zlcmlmaw VkIjpmYWxzZSwic3ViIjoiYTliNjQzYjMtOTY0NC00M2FjLWFlNzQtY2M4YTE0YjgyMWJjIn0sInJvbGUiOiJ
hdXRoZW50aWNhdGVkIiwiYWFsIjoiYWFsMSIsImFtciI6W3sibWV0aG9kIjoicGFzc3dvcmQiLCJ0aW1lc3RhbXAiOjE3NTgwNz
I4OTB9XSwic2Vzc2lvbl9pZCI6ImM3MDRiMDk4LTFhM2UtNDMxMi1iMjc1LTYwY2VlN2QzOTBlZSIsImlzX2Fub255bW91cyI6Z
mFsc2V9.XijKeWPbjwJlooCZEb0U7VQxBX3P4yvHAcAhS1ZBvGc", "content-profile": "public", "content-type":
"application/json", "prefer": "resolution=merge-duplicates", "x-client-info":
"supabase-js-react-native/2.49.5-next.1"}}, "method": "POST", "signal": undefined}
```


4. The Web Server (WS) makes an insert query to **`user_devices`** table in the Database (DB) to store the FCM registration token

2) End-user B transfers money to End-user A, which triggers that notification.



1. The End-user B inputs End-user A account number (see User Story 4)

a. To complete the transfer, the Client App (CA) sends a series of requests via REST API to the Web server, specifically inserting a new transaction record to the **`transactions`** table in the Database (DB) via Postgres connection


```
REQUEST:
https://vomohccmapvpspaupbah.supabase.co/rest/v1/transactions?columns=%22account_id%22%2C%22booking
_datetime%22%2C%22amount%22%2C%22currrency%22%2C%22credit_debit%22%2C%22description%22%2C%22transac
tion_type%22%2C%22status%22 {"body":
"[{\"account_id\":\"6e7084a4-da6c-48eb-bd16-6f9f50de1c5e\",\"booking_datetime\":\"2025-09-17T01:40:
17.448Z\",\"amount\":50,\"currency\":\"SGD\",\"credit_debit\":\"Debit\",\"description\":\"Transfer
to 00153940154\",\"transaction_type\":\"Online
Transfer\",\"status\":\"Booked\"},{\"account_id\":\"7769d110-7ee6-4c32-a5ef-a06f59ed6fce\",\"bookin
g_datetime\":\"2025-09-17T01:40:17.448Z\",\"amount\":50,\"currency\":\"SGD\",\"credit_debit\":\"Cre
dit\",\"description\":\"Transfer from 00162624385\",\"transaction_type\":\"Online
Transfer\",\"status\":\"Booked\"}]", "headers": {"map": {"apikey":
"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJzdXBhYmFzZSIsInJlZiI6InZvbW9oY2NtYXB2cHNwYXVwYmFoI
iwicm9sZSI6ImFub24iLCJpYXQiOjE3NDg0ODA2MjQsImV4cCI6MjA2NDA1NjYyNH0.kAtm3_e8PUjQGsacDTt7nzrBmQ49H-wU
4J4_biPMSZQ", "authorization": "Bearer
eyJhbGciOiJIUzI1NiIsImtpZCI6Ik4vampuNklBTGRLeHZpRmUiLCJ0eXAiOiJKV1QifQ.eyJpc3MiOiJodHRwczovL3ZvbW9o
Y2NtYXB2cHNwYXVwYmFoLnN1cGFiYXNlLmNvL2F1dGgvdjEiLCJzdWIiOiJhOWI2NDNiMy05NjQ0LTQzYWMtYWU3NC1jYzhhMTR
iODIxYmMiLCJhdWQiOiJhdXRoZW50aWNhdGVkIiwiZXhwIjoxNzU4MDc2NDkwLCJpYXQiOjE3NTgwNzI4OTAsImVtYWlsIjoidG
VzdEB0ZXN0LmNvbSIsInBob25lIjoiIiwiYXBwX21ldGFkYXRhIjp7InByb3ZpZGVyIjoiZW1haWwiLCJwcm92aWRlcnMiOlsiZ
W1haWwiXX0sInVzZXJfbWV0YWRhdGEiOnsiZW1haWwiOiJ0ZXN0QHRlc3QuY29tIiwiZW1haWxfdmVyaWZpZWQiOnRydWUsInBo
b25lX3ZlcmlmaWVkIjpmYWxzZSwic3ViIjoiYTliNjQzYjMtOTY0NC00M2FjLWFlNzQtY2M4YTE0YjgyMWJjIn0sInJvbGUiOiJ
hdXRoZW50aWNhdGVkIiwiYWFsIjoiYWFsMSIsImFtciI6W3sibWV0aG9kIjoicGFzc3dvcmQiLCJ0aW1lc3RhbXAiOjE3NTgwNz
I4OTB9XSwic2Vzc2lvbl9pZCI6ImM3MDRiMDk4LTFhM2UtNDMxMi1iMjc1LTYwY2VlN2QzOTBlZSIsImlzX2Fub255bW91cyI6Z
mFsc2V9.XijKeWPbjwJlooCZEb0U7VQxBX3P4yvHAcAhS1ZBvGc", "content-profile": "public", "content-type":
"application/json", "prefer": "", "x-client-info": "supabase-js-react-native/2.49.5-next.1"}},
"method": "POST", "signal": undefined}
```


2. Upon the new insert, the PostgRest Web Server (WS) will send a request to inform the new transaction record via REST API to Functions Web Server (WS) - a serverless function

   a. The serverless function first retrieves the FCM registration token via REST API to the Web server, and accesses the **`user_devices`** table in the Database (DB) via Postgres connection.

   b. The serverless function then requests for an access token via REST API to Google's OAuth 2.0 for authorisation

```
Request to serverless function:
{
  "event_message": "Request =  Request {\n  bodyUsed: false,\n  headers: Headers {\n    accept: \"*/*\",\n
  \"accept-encoding\": \"gzip\",\n    authorization: \"Bearer
  eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJzdXBhYmFzZSIsInJlZiI6InZvbW9oY2NtYXB2cHNwYXVwYmFoIiwicm9sZSI6InNlcn
  ZpY2Vfcm9sZSIsImlhdCI6MTc0ODQ4MDYyNCwiZXhwIjoyMDY0MDU2NjI0fQ.WcUibQGOXF8h9jFXdeoU9ZnmMReDOKptVQq99WWrUSs\",\n
  baggage: \"sb-request-id=01995554-67d8-76f3-9918-df0e612cd367\",\n    \"cdn-loop\": \"cloudflare; loops=1;
  subreqs=1\",\n    \"cf-connecting-ip\": \"52.77.5.167\",\n    \"cf-ew-via\": \"15\",\n    \"cf-ray\":
  \"9804e51302366590-SIN\",\n    \"cf-visitor\": '{\"scheme\":\"https\"}',\n    \"cf-worker\": \"supabase.co\",\n
  \"content-length\": \"310\",\n    \"content-type\": \"application/json\",\n    host:
  \"edge-runtime.supabase.com\",\n    \"sb-request-id\": \"01995554-67d8-76f3-9918-df0e612cd367\",\n
  \"user-agent\": \"pg_net/0.14.0\",\n    \"x-amzn-trace-id\": \"Root=1-68ca1183-2f4ac7056ae6244e24a56a08\",\n
  \"x-forwarded-for\": \"52.77.5.167,52.77.5.167, 13.248.127.236\",\n    \"x-forwarded-port\": \"443\",\n
  \"x-forwarded-proto\": \"https\"\n  },\n  method: \"POST\",\n  redirect: \"follow\",\n  url:
  \"http://vomohccmapvpspaupbah.supabase.co/send-notification\"\n}\n",
  "id": "d0466fc2-f86b-4910-bcb8-86c3b7fa9f48",
  "metadata": [
    {
      "boot_time": null,
      "cpu_time_used": null,
      "deployment_id": "vomohccmapvpspaupbah_4c70ad3d-1983-4328-a631-a7f3c4f9c04f_5",
      "event_type": "Log",
      "execution_id": "27850e28-78e2-4656-ac14-5f2da482b011",
      "function_id": "4c70ad3d-1983-4328-a631-a7f3c4f9c04f",
      "level": "info",
      "memory_used": [],
      "project_ref": "vomohccmapvpspaupbah",
      "reason": null,
      "region": "ap-southeast-1",
      "served_by": "supabase-edge-runtime-1.69.4 (compatible with Deno v2.1.4)",
      "timestamp": "2025-09-17T01:40:19.182Z",
      "version": "5"
    }
  ],
  "timestamp": 1758073219182000
}
```


3. The serverless function sends a request consisting the FCM registration token via REST API to FCM backend with the access token to deliver the push notification to the Google Play services of End-user A device

4. The Google Play services of End-user A device then delivers that request to the specific Client App (CA)

5. The Client App of End-user A's device receives the push notification

Reference: https://firebase.google.com/docs/cloud-messaging/fcm-architecture